

歐盟 CRA 如何影響全球動向一

活用開源以妥善因應各國合規管理

v.20260915

群牧開源管理顧問有限公司 / 鈞理知識產權事務所 法制顧問

CC Taiwan Chapter Lead / CC 台灣計畫主持人、台灣開源法律網絡 OSLN.tw 共同創辦人

Legal Adviser @ Herding Open Source Management Consultants Ltd. & Gemly Int' l IPR Office

林誠夏 / Lucien Cheng-hsia Lin Email: lucien.cc@gmail.com

LinkedIn: <https://tw.linkedin.com/in/lucienchlin>

TISSA 開源軟體生態促進會：AI 時代的企業開源備忘錄

2026.09.23



lucien.cc@gmail.com

林誠夏 / Lucien C.H. Lin

本職：

- 1、**群牧**開源管理顧問有限公司 / **鈞理**知識產權事務所 法制顧問
- 2、**CC Taiwan** Chapter Lead、**台灣開源法律網絡** 共同創辦人
- 3、**究心公益**股份有限公司獨立董事

歷任與現任：

- 1、行政院、國發會、文化部、故宮博物院、考試院、銓敘部政府**資料開放諮詢小組**會議委員
- 2、臺北市政府公共參與組**市政顧問**

<http://tw.linkedin.com/in/lucienchlin>

政府資料開放授權條款

+

← → ↺ 🏠

🔒 https://data.gov.tw/license

120% ... 📄 🌐 🗨️ 📧 📱 📺

 政府資料開放平臺
DATA.GOV.TW

網站導覽

EN

客服小幫手

線上客服

會員登入

⋮

資料集 ▾

資料故事館 ▾

互動專區 ▾

消息專區 ▾

諮詢小組

授權條款

關於平臺 ▾

政府資料開放授權條款－第1版

中文

English

政府資料開放授權條款－第1版

中華民國104年7月27日訂定

為便利民眾共享及應用政府資料、促進及活化政府資料應用、結合民間創意提升政府資料品質及價值、優化政府服務品質，訂定本條款。

一、定義

(一)資料提供機關：指將職權範圍內取得或作成之各類電子資料，透過本條款釋出予公眾之政府機關（構）、公營事業機構、公立學校及行政法人。

(二)使用者：指依本條款規定取得開放資料，並對其利用之自然人、法人或團體，包括依本條款授權使用者再轉授權利用之人或團體。

(三)開放資料：指資料提供機關擁有完整著作財產權，或經授權得再轉授權第三人利用之資料，並以公開、可修改，且無不必要技術限制之格式提供者，包括但不限於下列著作：

1. 編輯著作：選擇、編排具有創作性，而可受著作權法保護之資料庫或其他結構化資料組合。
2. 素材：指開放資料集合物中，其他可受著作權法保護之獨立著作。

<https://data.gov.tw/license>

臺灣主權AI訓練語料庫 (Beta版)

關於語
料庫

申請須
知

語料資料集

授權條
款

合作夥
伴

登入/註冊

臺灣主權AI訓練語料授權條款-第1版

前言：

為促進以人為本的人工智慧（AI）研發與應用，增進公眾利益、提升在地文化價值，並促進自然語料的永續發展，特訂立本授權條款，以加速並提倡相關資料之流通。

一、名詞定義

1. **授權人**：指具備合法權利的個人或單位，依據本授權條款提供其所管理之語料資料予被授權人，以協助被授權人在被明確同意的基礎下，使用該等語料資料於人工智慧的訓練與學習。

<https://taic.moda.gov.tw/content/license>

職場實務應用的角度

探索開源授權與商務策略間的正確認知

及 EU CRA 合規因應之道

大綱

0. 基本提要與開源定義

1. CRA 歐盟數位韌性法案是什麼？
2. CRA 與過往資安法規的差異
3. 開源與 CRA 在立法歷程的衝突與調適

4. SBOM 的法定地位與 Forking 誤區

5. 向開源取經整理有效的 SBOM
6. 善用真開源因應 CRA 合規要求
7. 開源與各國法令的交集與調適

0. 基本提要與開源定義

**不是為了商用而啟動開源
而是產生效益後擴大商用**

從歷史觀點來說



<http://readwrite.com/2013/12/19/the-genius-of-linux-is-community-not-technology#awesm=~ovezrNTT0huSXw>

Company	Changes	Total
None	12,550	13.6%
Red Hat	9,483	10.2%
Intel	8,108	8.8%
Texas Instruments	3,814	4.1%
Linaro	3,791	4.1%
SUSE	3,212	3.5%
Unknown	3,032	3.3%
IBM	2,858	3.1%
Samsung	2,415	2.6%
Google	2,255	2.4%
Vision Engraving Systems	2,107	2.3%
Consultants	1,529	1.7%
Wolfson Microelectronics	1,516	1.6%
Oracle	1,248	1.3%
Broadcom	1,205	1.3%

Company	Changes	Total
NVIDIA	1,192	1.3%
Freescale	1,127	1.2%
Ingics Technology	1,075	1.2%
Renesas Electronics	1,010	1.1%
Qualcomm	965	1.0%
Cisco	871	0.9%
The Linux Foundation	840	0.9%
Academics	831	0.9%
AMD	820	0.9%
Inktank Storage	709	0.8%
NetApp	707	0.8%
LINBIT	705	0.8%
Fujitsu	694	0.7%
Parallels	684	0.7%
ARM	664	0.7%

<http://readwrite.com/2013/12/19/the-genius-of-linux-is-community-not-technology#awesm=~ovezrNTT0huSXw>

Open Source

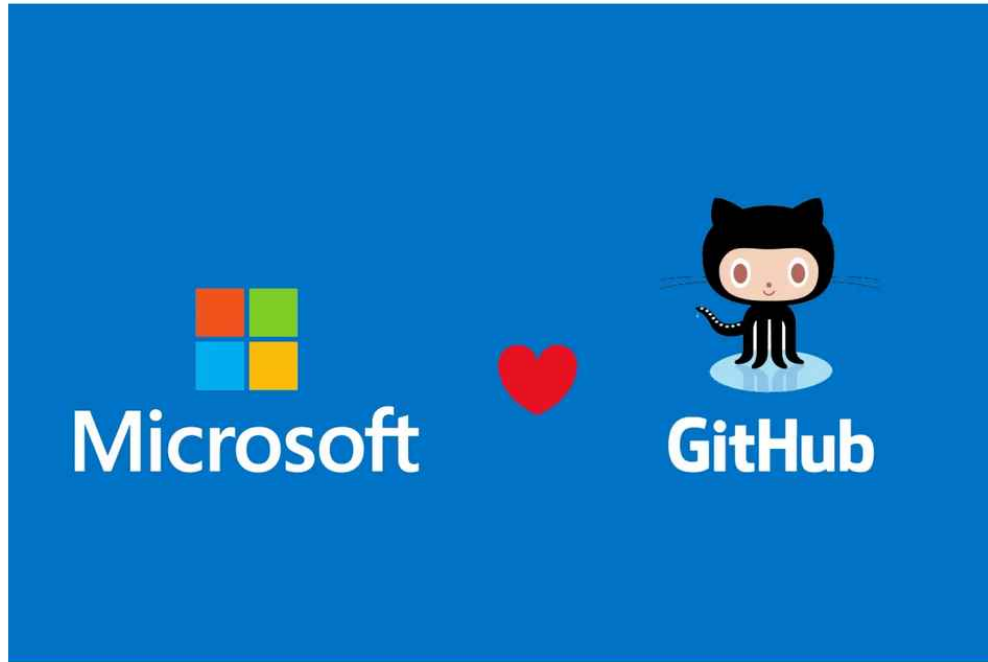
當代**跨界合作**的有效手段

Ecosystem

建構開放標準統合
軟硬整合的生態系

+ TECH + MICROSOFT

Microsoft confirms it's acquiring GitHub for \$7.5 billion



by + Tom Warren

Jun 4, 2018, 9:02 PM GMT+8

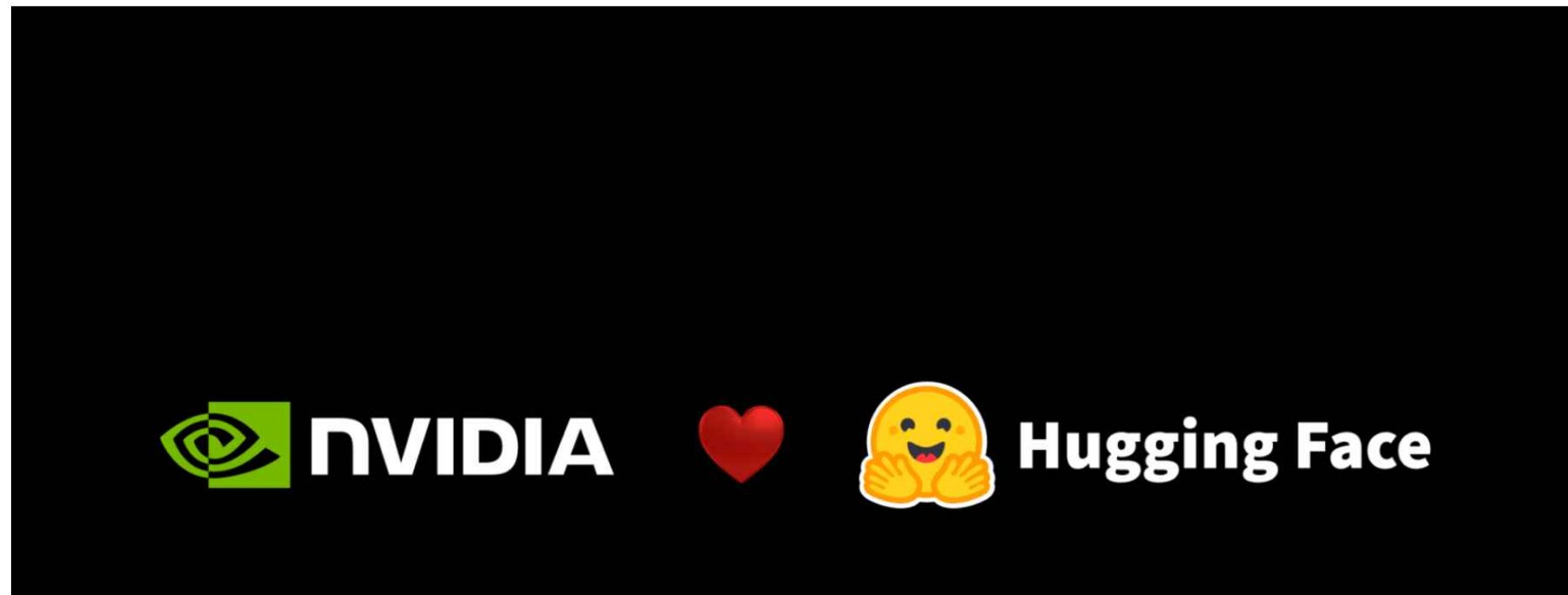
[Link](#) [Share](#) [Gift](#) [0 Comments](#)

<https://www.theverge.com/2018/6/4/17422788/microsoft-github-acquisition-official-deal>

NVIDIA to Acquire Hugging Face

September 3, 2026 by Jensen Huang

3 mins | 0 Comments | Share



<https://blogs.nvidia.com/blog/nvidia-to-acquire-hugging-face/>

可以被自由修改、自由散布，沒有使用期
間、範圍、目的限制的軟體專案，就是 / 才
是真正的自由開源軟體專案。

Licenses by Name | Open

+

← → ↺

opensource.org/licenses/alphabetical

🔍 ▶ ☆ ⚙️ 👤 ⋮



Open Source Initiative

Guaranteeing the 'our' in source...

ABOUT ▾LICENSES ▾COMMUNITY ▾RESOURCES ▾NEWS & EVENTS ▾JOIN ▾

Licenses by Name

The following licenses have been approved by the OSI. The parenthesized expression following a license name is its SPDX short identifier (if one exists).

- 0-clause BSD License (0BSD)
- 1-clause BSD License (BSD-1-Clause)
- 2-clause BSD License (BSD-2-Clause)
- 3-clause BSD License (BSD-3-Clause)
- Academic Free License 3.0 (AFL-3.0)
- Adaptive Public License (APL-1.0)
- Apache Software License 1.1 (Apache-1.1) (superseded)
- Apache License 2.0 (Apache-2.0)
- Apple Public Source License (APSL-2.0)
- Artistic license 1.0 (Artistic-1.0) (superseded)
- Artistic License 2.0 (Artistic-2.0)



open source
initiative
Approved License

Keep up with Open Source

Sign up with your email to receive our newsletter — your resource for industry news, upcoming events, insights from Open Source thought leaders and more.

Sign up with your email to receive OSI's newsletter — your resource for industry news,



<https://opensource.org/licenses/alphabetical>

0-clause BSD License (0BSD), 1-clause BSD License (BSD-1-Clause), 2-clause BSD License (BSD-2-Clause), 3-clause BSD License (BSD-3-Clause), Academic Free License 3.0 (AFL-3.0), Adaptive Public License (APL-1.0), Apache Software License 1.1 (Apache-1.1) (superseded), Apache License 2.0 (Apache-2.0), Apple Public Source License (APSL-2.0), Artistic license 1.0 (Artistic-1.0) (superseded), Artistic License 2.0 (Artistic-2.0), Attribution Assurance License (AAL), Boost Software License (BSL-1.0), 3-clause BSD License, 2-clause BSD License, 1-clause BSD License, 0-clause BSD license, BSD-3-Clause-LBNL, BSD+Patent (BSD-2-Clause-Patent), CERN Open Hardware Licence Version 2 - Permissive, CERN Open Hardware Licence Version 2 - Weakly Reciprocal, CERN Open Hardware Licence Version 2 - Strongly Reciprocal, CeCILL License 2.1 (CECILL-2.1), Common Development and Distribution License 1.0 (CDDL-1.0), Common Public Attribution License 1.0 (CPAL-1.0), Common Public License 1.0 (CPL-1.0) (superseded), Computer Associates Trusted Open Source License 1.1 (CATOSL-1.1), Cryptographic Autonomy License v.1.0 (CAL-1.0), CUA Office Public License Version 1.0 (CUA-OPL-1.0) (retired), Eclipse Public License 1.0 (EPL-1.0) (superseded), Eclipse Public License 2.0 (EPL-2.0), eCos License version 2.0 (eCos-2.0), Educational Community License, Version 1.0 (ECL-1.0) (superseded), Educational Community License, Version 2.0 (ECL-2.0), Eiffel Forum License V1.0 (EFL-1.0) (superseded), Eiffel Forum License V2.0 (EFL-2.0), Entessa Public License (Entessa), EU DataGrid Software License (EUDatagrid), European Union Public License 1.2 (EUPL-1.2) (links to every language's version on their site), Fair License (Fair), Framework License (Framework-1.0), Free Public License 1.0.0 (0BSD), GNU Affero General Public License version 3 (AGPL-3.0), GNU General Public License version 2 (GPL-2.0), GNU General Public License version 3 (GPL-3.0), GNU Lesser General Public License version 2.1 (LGPL-2.1), GNU Lesser General Public License version 3 (LGPL-3.0), Historical Permission Notice and Disclaimer (HPND), IBM Public License 1.0 (IPL-1.0), Intel Open Source License (Intel) (retired), IPA Font License (IPA), ISC License (ISC), Jabber Open Source License (retired), LaTeX Project Public License 1.3c (LPPL-1.3c), Lawrence Berkeley National Labs BSD Variant License (BSD-3-Clause-LBNL), Licence Libre du Québec – Permissive (LiLiQ-P) version 1.1 (LiliQ-P), Licence Libre du Québec – Réciprocité (LiLiQ-R) version 1.1 (LiliQ-R), Licence Libre du Québec – Réciprocité forte (LiLiQ-R+) version 1.1 (LiliQ-R+), Lucent Public License ("Plan9"), version 1.0 (LPL-1.0) (superseded), Lucent Public License Version 1.02 (LPL-1.02), Microsoft Public License (MS-PL), Microsoft Reciprocal License (MS-RL), MirOS Licence (MirOS), MIT License (MIT), MIT No Attribution License (MIT-0), MITRE Collaborative Virtual Workspace License (CVW) (retired), Motosoto License (Motosoto), Mozilla Public License 1.0 (MPL-1.0) (superseded), Mozilla Public License 1.1 (MPL-1.1) (superseded), Mozilla Public License 2.0 (MPL-2.0), Mulan Permissive Software License v2 (MulanPSL - 2.0), Multics License (Multics), NASA Open Source Agreement 1.3 (NASA-1.3), Naumen Public License (Naumen), Nethack General Public License (NGPL), Nokia Open Source License (Nokia), Non-Profit Open Software License 3.0 (NPOSL-3.0), NTP License (NTP), OCLC Research Public License 2.0 (OCLC-2.0), Open Group Test Suite License (OGTSL), Open Software License 1.0 (OSL-1.0) (superseded), Open Software License 2.1 (OSL-2.1) (superseded), Open Software License 3.0 (OSL-3.0), OpenLDAP Public License Version 2.8 (OLDAP-2.8), OSET Public License version 2.1, PHP License 3.0 (PHP-3.0) (superseded), PHP License 3.01 (PHP-3.01), The PostgreSQL License (PostgreSQL), Python License (Python-2.0) (overall Python license), CNRI Python license (CNRI-Python) (CNRI portion of Python License), Q Public License (QPL-1.0), RealNetworks Public Source License V1.0 (RPSL-1.0), Reciprocal Public License, version 1.1 (RPL-1.1) (superseded), Reciprocal Public License 1.5 (RPL-1.5), Ricoh Source Code Public License (RSCPL), SIL Open Font License 1.1 (OFL-1.1), Simple Public License 2.0 (SimPL-2.0), Sleepycat License (Sleepycat), Sun Industry Standards Source License (SISSL) (retired), Sun Public License 1.0 (SPL-1.0), Sybase Open Watcom Public License 1.0 (Watcom-1.0), Universal Permissive License (UPL), University of Illinois/NCSA Open Source License (NCSA), Upstream Compatibility License v1.0, Unicode Data Files and Software License, The Unlicense, Vovida Software License v. 1.0 (VSL-1.0), W3C License (W3C), wxWindows Library License (WXwindows), X.Net License (Xnet), Zero-Clause BSD (0BSD), Zope Public License 2.0 (ZPL-2.0) (superseded), Zope Public License 2.1 (ZPL-2.1), zlib/libpng license (Zlib)

OSI-approved Licenses sorted by name by the date 2021.10.18: <https://opensource.org/licenses/alphabetical>

開源軟體的**三大分類**

大家都必須要
一直自由

LGPL-2.1 / LGPL-2.0 /
LGPL-3.0

MPL-2.0 /
CDDL-1.0 / CDDL-1.1

幾近無拘無束
的自由



GPL-2.0 / GPL-3.0

EPL-2.0 Apache-2.0 / AFL-3.0

MIT / BSD-3-Clause /
BSD-2-Clause

有點自由又不會太自由

AGPL-3.0 / OSL-3.0

開源軟體的**六大特性**

開源授權的六大特性

符合 FSF 自由軟體定義或 OSI 開放源碼定義者

1 、非專屬授權 **non-exclusive**

2 、不可撤回 **irrevocable**

3 、免授權金 **royalty-free**

4 、不附隨擔保 **no warranties**

5 、不限制目的、時間、地域

for any purpose, perpetual, worldwide

6 、使用、重製、修改、發布

freedom to run, copy, modify, and redistribute

開源軟體：

1. 只要合規、取得的開源授權永久不會撤回
2. 使用規則就是依取得時那份條款
3. 要求註引出處、或必要時相同方式分享，但原則上不會有其他限制。

沒有比（真正的）**開源**更浪漫的事……

Love is not love 愛非愛

Which alters when it alteration finds, 若它一變即改

Or bends with the remover to remove. 或因對方離開，也就離開

O no! It is an **ever-fixed mark** 愛是永恆不移的標記

That looks on tempests and is **never shaken**. 縱處動盪也不動搖

—William Shakespeare, Sonnet 116: “Let Me Not to the Marriage of True Minds”



開源授權條款為骨、開源程式碼協作為肉，整體才能建構可維運的共生生態系。

1. **CRA** 歐盟數位韌性法案是什麼？

Cyber Resilience Act



Apache Log4j

Contents

Shortcuts

Features

Apache Log4j is a versatile, industrial-grade Java logging framework composed of an API, its implementation, and components to assist the deployment for various use cases. The project is actively maintained by a [team](#) of volunteers and [supported](#) by a big community.

<https://logging.apache.org/log4j/2.x/index.html>



THE WALL STREET JOURNAL.

WSJ PRO

White House Convenes Open-Source Security Summit Amid Log4j Risks

Widespread use of open-source technologies and their maintenance by small groups creates national-security concerns, officials say

By James Rundle

WSJ PRO

Updated Jan. 13, 2022 8:09 pm ET

<https://www.wsj.com/articles/white-house-convenes-open-source-security-summit-amid-log4j-risks-11642119406>

Open Source Security x +

openssf.org

Download the Free eBook: [Built to Last: Understanding the European Cyber Resilience Act \(CRA\)](#)

 OpenSSF
OPEN SOURCE SECURITY FOUNDATION

About ▾ Projects ▾ Learning ▾ Community ▾ Public Policy ▾ Blog & News ▾ Events ▾ [Join](#) 🔍



Navigating the EU's Cyber Resilience Act (CRA)? Get our free eBook.

[Free eBook](#)

The Open Source Security Foundation (OpenSSF) is a community of software developers, security engineers, and more who are working together to secure open source software for the greater public good.



<https://openssf.org/>

More than four years later, a contact at one of the largest cloud providers told Ombredanne that **more than 20 percent** of its Java customers were **still running a flaw** that was already years old at discovery.



EU Cyber Resilience Act, CRA

Manufacturers shall, upon **identifying a vulnerability** in a component, including in an **open source** component, which is integrated in the product with **digital elements**, **report the vulnerability to the person or entity maintaining the component.**

IoT and More

Products with digital elements, PDE

2. CRA 的責任要求

與過往資安法規的差異

PSTI- 英國產品安全和電信基礎設施法案

Product Security and Telecommunications Infrastructure Bill---2024

RED-DA- 歐盟無線電設備法律指令授權法案

EU Radio Equipment Directive - Delegated Act--2025

ETSI EN 303 645/ 歐洲電信標準協會

Security by Design-- 基於安全的設計

1. 不要綁定預設通用密碼
2. 弱點通報的管理與執行
3. 保持軟體更新
4. 機敏安全參數的確保
5. 採安全方式通訊
6. 減少暴露在攻擊面的可能
7. 確保軟體完整狀態
8. 確保個人資料儲放安全
9. 系統抗中斷的韌性
10. 透過遙測數據檢測系統異常
11. 便利使用者刪除個人資料
12. 簡化暨強化設備安裝和維護的步驟
13. 驗證輸入資料

法律責任的轉變：在 **CRA** 框架下，將
FOSS 整合進商業產品的「**製造商**」，
其法律責任**與過往有何本質上的不同**？



《**優生保健法**》

《**兒童及少年福利與權益保障法**》



[首頁](#) / 詞目：生囡師仔，飼囡師傅。（目前頁面）

生囡師仔，飼囡師傅。

Senn-kiánn sai-á, tshī kiánn sai-hū.

釋義

1. 生孩子是學徒，養育孩子是師傅。比喻生小孩瓜熟蒂落算不上本事，要把孩子養育成有用的人才是真本領。

用例：

欲對紅紅幼幼的嬰仔，晟養到成樣，愛了佢濟時間、精神恰氣力，古早人毋才會講：「生囡師仔，飼囡師傅」。

Beh uì âng-âng-iù-iù ê enn-á, tshiânn-ióng kàu tsiânn-iūnn, ài liáu guā-tsê sî-kan, tsing-sîn kah khui-làt, kóo-tsá-lâng m̄-tsia̍h ē kóng, “Senn-kiánn sai-á, tshī kiánn sai-hū”.

(要從紅嫩的小嬰兒，養育到成材，要花多少時間、精神和力氣，古人才會說：「生孩子是學徒，養育孩子是師傅。」)

Single Reporting Platform (SRP)

[Home](#) / [Topics](#) / [Product Security](#) / [Single Reporting Platform \(SRP\)](#)

[← Back to main topic](#)

SUBTOPICS

[Single Reporting Platform \(SRP\)](#)

CONTENT



→ [Frequently Asked Questions](#)

→ [CRA SRP guidance - AR Interface functions](#)

→ [CRA SRP guidance - AR Notification submission and update](#)

→ [CRA SRP guidance - AR User registration](#)



The Cyber Resilience Act (CRA) introduces the Single Reporting Platform (SRP) for cybersecurity incident reporting in the EU Digital Single Market.



CRA
SINGLE
REPORTING
PLATFORM

The Single Reporting Platform (SRP) shall become a technical tool for the reporting of actively exploited vulnerabilities and incidents impacting products with digital elements in the EU Digital Single Market.

Under the [Cyber Resilience Act](#) (CRA), manufacturers of products with digital elements are mandated to report actively exploited vulnerabilities and severe incidents having an impact on the security of the products.

As of 11 September 2026 onwards, the SRP will be used by CSIRTs and manufacturers for mandatory reporting and could be used by any natural/legal persons for voluntary reporting.

Throughout 2025 and 2026, ENISA is taking the necessary steps to support the successful implementation of the platform.



IoT / Digital Elements 商品的資安維護（擔保期間的修復、通報、告知）

1. 修復：Expected lifetime ；原則至少 5 年
2. 通報：ENISA ／ CSIRT - Single Reporting Platform
24hr ／ 72hr ／ 14 days （漏洞） ； 1 month （嚴重事件）
3. 告知：Affected users

IoT / Digital Elements 商品的資安維護 (擔保期間的修復、通報、告知)

1. 通報：ENISA / CSIRT - Single Reporting Platform

2026.9.11 率先生效

2. CE 標示及其他主要義務：2027.12.11 全面適用

3. 開源與 CRA

在立法歷程的衝突與調適



Home

DNS

Routing

Research

Newsletter



Sign in

Subscribe

Policy

What I learned in Brussels: the Cyber Resilience Act



Team NLnet Labs

Feb 7, 2024 • 6 min read



<https://blog.nlnetlabs.nl/what-i-learned-in-brussels-the-cyber-resilience-act/>

開源與 CRA 在立法歷程的衝突與調適

- 產品製造商、販售者擔負資安 - 誰做誰負責
- 純粹開源分享並非產品 - 做開源的不一定直接賺錢
- 然將開源元件商用即課產品責任 - 誰賺誰負責
- 開源有其減輕配套然應透明可及 - 增訂開源除外規定，但也希望開源原生者，能提供一些資安提升上的幫助！

CRA 並不是要求所有寫程式的人都負責，而是要求把產品放上市場、靠產品賺錢的人，必須建立完整的資安責任鏈。

The **CRA** does not require everyone who writes software to be responsible. Instead, it requires those who place products on the market and profit from them to establish a complete cybersecurity accountability chain.

4. SBOM 的法定地位與誤區一

Forking 與供應鏈追蹤的衝突

SBOM 的製作與資安驗證協力

Software Bill of Materials

- Software Supply Chain Security Guidance +
- Cybersecurity Labeling for Consumers +
- Workshops & Call for Papers
- News & Updates
- Engage
- Fact Sheet
- Resources
- FAQs
- Cybersecurity @ NIST

Improving the Nation's Cybersecurity: NIST's Responsibilities Under the May 2021 Executive Order

[Overview](#) | [Completed Assignments](#) | [Latest Updates](#)

OVERVIEW

The President's Executive Order (EO) 14028 on [Improving the Nation's Cybersecurity](#) issued on May 12, 2021, charges multiple agencies – including NIST – with enhancing cybersecurity through a variety of initiatives related to the security and integrity of the software supply chain.

Section 4 directs NIST to solicit input from the private sector, academia, government agencies, and others and to identify existing or develop new standards, tools, best practices, and other guidelines to enhance software supply chain security. Those guidelines, **which are ultimately aimed at federal agencies but which also are available for industry**

軟體物料清單 (SBOM in **SPDX** under **US NIST** guidance)

- 1 、作者名稱 (Author Name) : [Apache Software Foundation](#)
- 2 、供應商名稱 (Supplier Name) : [Apache Software Foundation](#)
- 3 、元件名稱 (Component Name) : [apache_httpd](#)
- 4 、版本訊息 (Version String) : [1.3.26](#)
- 5 、元件機讀辨識碼 (Component Hash) :
[MD5 2973db71f0c4b4ccb35336152dda0b30](#)
- 6 、唯一識別碼 (Unique Identifier) : [httpd@1.3.26](#)
- 7 、與其他元件的關係 (Relationship) :
[openssl/openssl@0.9.8a PREREQUISITE_OF apache/httpd@1.3.26](#)

possible, the users of the relevant products with digital elements placed on the market, of the impending cessation of operations.

24. The Commission may, by means of implementing acts taking into account European or international standards and best practices, specify the format and elements of the software bill of materials referred to in Part II, point (1), of Annex I. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 62(2).

25. In order to assess the dependence of Member States and of the Union as a whole on software components and in particular on components qualifying as free and open-source software, ADCO may decide to conduct a Union wide dependency assessment for specific categories of products with digital elements. For that purpose, market surveillance authorities may request manufacturers of such categories of products with digital elements to provide the relevant **software bills of materials** as referred to in Part II, point (1), of Annex I. On the basis of such information, the market surveillance authorities may provide ADCO with anonymised and aggregated information about software dependencies. ADCO shall submit a report on the results of the dependency assessment to the Cooperation Group established pursuant to Article 14 of Directive (EU) 2022/2555.

Article 14

Reporting obligations of manufacturers

1. A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.
2. For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit:
 - (a) an early warning notification of an actively exploited vulnerability, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, and

 **Table of contents**

States on the territory of which the manufacturer

軟體物料清單 (CRA Annex I 第 II 部第 1 點)

製造商必須識別並記錄產品所含元件與漏洞，包括製作 **SBOM** ；格式須為**常用、機器可讀**，且至少涵蓋第一層**相依元件**（top-level **dependencies**）。

Manufacturers of products with digital elements shall:

(1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

開源授權的六大特性

符合 FSF 自由軟體定義或 OSI 開放源碼定義者

1 、非專屬授權 **non-exclusive**

2 、不可撤回 **irrevocable**

3 、免授權金 **royalty-free**

4 、不附隨擔保 **no warranties**

5 、不限制目的、時間、地域

for any purpose, perpetual, worldwide

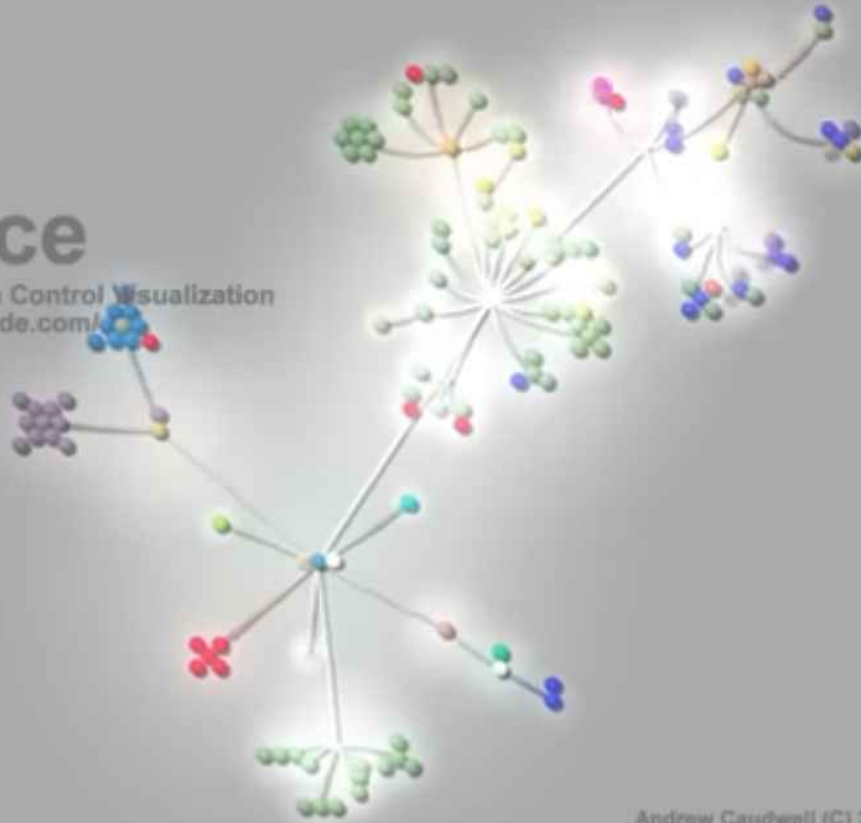
It Forks

6 、使用、重製、修改、發布

freedom to **run, copy, modify, and redistribute**

Gource

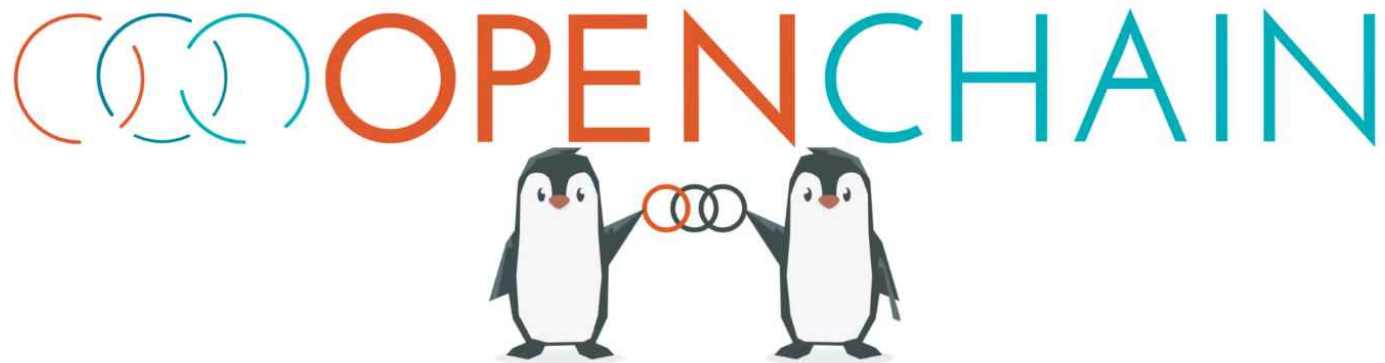
Software Version Control Visualization
gource.googlecode.com/



Andrew Caudwell (C) 2009 - TheAlphaBlenders.Com

<https://gource.io/>
<https://youtu.be/NjUuAuBcoqs>

5. 從 Supply Chain 到 Supply Tree- 向開源取經整理有效的 SBOM



BUILDING TRUST IN THE SUPPLY CHAIN SINCE 2016

Our vision is a supply chain where open source is delivered with trusted and consistent process management information.

Our mission is to make that happen.

<https://openchainproject.org/>

商務使用 **開源軟體** 的義務與權利

義務

- 1 、做好相關標示 **Copyright Notice + Disclaimer**
- 2 、提供相對應必要源碼 **Corresponding Source**

權利

- 3 、之後，就能做幾乎**任何事情**

(111.4.29 修正)

招標機關(以下簡稱機關)及得標廠商(以下簡稱廠商)雙方同意依政府採購法(以下簡稱採購法)及其主管機關訂定之規定訂定本契約，共同遵守，其條款如下：

第一條 契約文件及效力

(一) 契約包括下列文件：

1. 招標文件及其變更或補充。
2. 投標文件及其變更或補充。
3. 決標文件及其變更或補充。
4. 契約本文、附件及其變更或補充。

L□其他。(內容由機關於招標時載明)

例：機關得就其取得之著作財產權，允許廠商支付對價，授權廠商使用。

6.廠商依本契約提供機關服務時，如使用開源軟體，應依該開源軟體之授權範圍，授權機關利用，並以執行檔及原始碼共同提供之方式交付予機關使用，廠商並應交付開源軟體清單（包括但不限於：開源專案名稱、出處資訊、原始著作權利聲明、免責聲明、開源授權條款標示與全文）。

(四)訂約機關為政府機關者，以政府機關所屬公法人為權利義務主體。

(五)廠商保證對於其受雇人或受聘人職務上完成之著作，依著作權法第 11 條第 1 項但書及第 12 條規定，與其受雇人或受聘人約定以廠商為著作人，享有著作人格權及著作財產權。惟此一約定僅止於廠商與其受

Credits

原始著作權利聲明、免責聲明、開源授權條款標示

Print

Abseil	show license - homepage
Accessibility Audit library, from Accessibility Developer Tools	show license - homepage
Activity	show license - homepage
Alliance for Open Media Video Codec	show license - homepage
Almost Native Graphics Layer Engine	show license - homepage
American Fuzzy Lop	show license - homepage
Android	show license - homepage
Android AppCompat Library v7	show license - homepage
Android AppCompat Library v7	show license - homepage
Android Arch-Common	show license - homepage
Android Arch-Runtime	show license - homepage

開源專案名稱

出處資訊

chrome://credits/

第三方授權

LineageOS 法律條款

Google 法律條款

系統 WebView 授權

第三方授權

- [/data/benchmarktest/libjavacore](#)
- [/data/benchmarktest64/libjavacc](#)
- [/data/nativetest/bsdiff_unittest/b](#)
- [/data/nativetest/libjavacore-unit-](#)
- [/data/nativetest/memory_replay_](#)
- [/data/nativetest64/bsdiff_unittes](#)
- [/data/nativetest64/libjavacore-ur](#)
- [/data/nativetest64/memory_repla](#)
- [/fake_packages/selinux_policy-ti](#)
- [/kernel](#)
- [/recovery/root/etc/mke2fs.conf](#)
- [/recovery/root/etc/mkshrc](#)
- [/recovery/root/nonplat_file_cont](#)
- [/recovery/root/nonplat_property_](#)
- [/recovery/root/plat_file_contexts](#)
- [/recovery/root/plat_property_con](#)
- [/recovery/root/sbin/bu](#)
- [/recovery/root/sbin/recovery.](#)
- [/recovery/root/sbin/toybox_static](#)
- [/recovery/root/sbin/update_engi](#)

第三方授權

Notices for file(s):

[/data/nativetest/bsdiff_unittest/b](#)
[/data/nativetest64/bsdiff_unittest](#)
[/system/lib/libbsdiff.a](#)
[/system/lib/libbspatch.a](#)
[/system/lib64/libbsdiff.a](#)
[/system/lib64/libbspatch.a](#)

This project governed by the foll
header to know the licenses appl

Copyright 2003-2005 Colin Perciva
All rights reserved

Redistribution and use in source
modification, are permitted provi
are met:

1. Redistributions of source code
notice, this list of condition
2. Redistributions in binary form



VLC for Android

Videolabs

3+

解除安裝

開啟

1,000
萬

下載次數

4.3
★★★★☆

217,811



媒體與影片

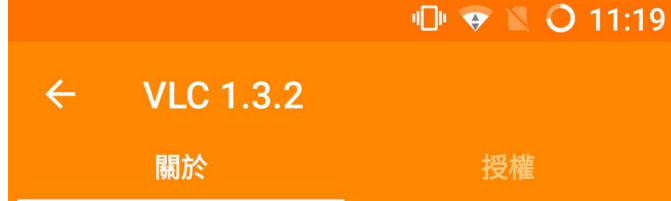


類似內容

VLC對於Android是最好的開源視頻
和音樂播放器，方便快捷！



新功能



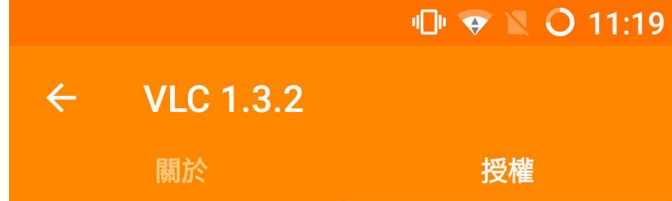
VLC for Android™

VLC for Android™ 移植自VLC媒體播放
器，是相當受歡迎的開源媒體播放器。此
Android™版本可以讀取大部分的媒體檔案
和網路串流。

Copyright © 1996–2015 by VideoLAN.

Edward Wang, Sébastien Toque, Adrien Maglo, Jean-Baptiste Kempf, Ludovic Fauvet, Rafaël Carré, Alexandre Perraud, Michael Merg, Martin Storsjö, Rémi Durauffort, Dominique Martinet, Jean-Philippe André, Felix Abecassis, Christoph Miebach, Hugo Beauzée-Luyssen, Felix Paul Kühne, John Mooring, Pavol Rusnak, Rohit Yadav, Tanguy Pruvot, Thomas Clavier, Asad Mehmood, Garret Kelly, Philipp Dreimann, Walter Heck, Thomas Guillem, Geoffrey Métais.
VLC Authors.

<http://www.videolan.org/vlc/>



VLC for Android

Copyright © 1996-2015 VideoLAN, VLC
authors

License

VLC for Android is licensed under the
[GNU General Public License, version 3 or
later](#) (herein referred to as GPL).

Sources

The sources to this application can be
retrieved at <http://git.videolan.org/?p=vlc-ports/android.git;a=tree;h=8ebcc4b;hb=8e>

1 著作權聲明

2 免責聲明

3 授權條款全文

4 程式（檔案）修改註記

5 配合各別授權條款要求的源碼

開源軟體清單

示範例

(Example for the FOSS list)

1. Project Name: [spring-ldap-core](#)

2. URL: <https://mvnrepository.com/artifact/org.springframework.ldap/spring-ldap/2.3.2.RELEASE>

3. Version: [2.3.2.RELEASE](#)

4. License Full name: [Apache License 2.0](#)

5. SPDX Identifier: [Apache-2.0](#)

6. Copyright Notice: [Copyright 2005-2013 the original author or authors.](#)

7. Disclaimer:

[Unless required by applicable law or agreed to in writing,](#)

[In no event and under no legal theory,](#)

8. Notes: [The full attribution to the original author or authors shall be getting access by the "@author" tag in the Source Files.](#)

SBOM 的建構挑戰：業界在建構與維護 SBOM 的過程中，通常會遇到哪些挑戰？

The Answer Was Already on the Shelf

The Answer Was Already on the Shelf

[Share](#)

Author(s): Jeffrey A. McGuire

How public money built defenses for open source software (way) before the law required them.

When the Last Line of Defense is the Weakest

Around 2016, Armijn Hemel took apart a KVM-over-IP switch. The box a sysadmin reaches for when a server stops answering, it opens a path into the machine over the network. This one ran a version of Linux that, by Hemel's estimate, was about 16 years old. The equipment designed to be a data center's last line of defense was the least defended thing in the rack.

Hemel dismantles firmware for a living, so this pattern is familiar. The



Image © weonnn, 123RF

Subscribe to our [Linux Newsletters](#)

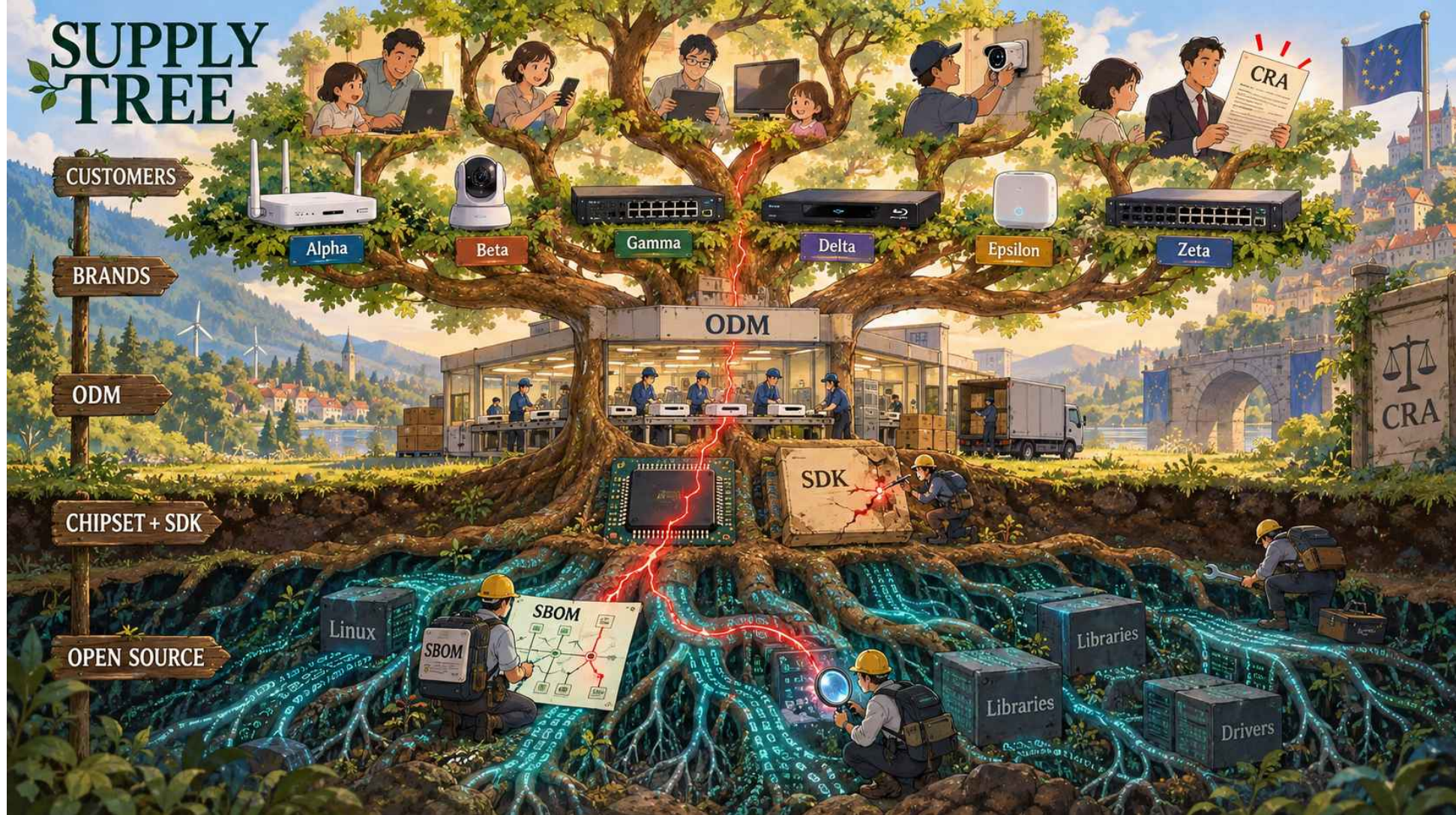
Find [Linux and Open Source Jobs](#)

Subscribe to our [ADMIN Newsletters](#)

Digital Autonomy

- [The Answer Was Already on the Shelf](#)
- [Changing the Chip Industry: How Public Investment Has Grown Open Silicon](#)
- [United Nations Open Source Portal Goes Live](#)
- [EU Open Source Strategy Plays Key Role in Tech Sovereignty Package](#)
- [France Says "Au Revoir" to Microsoft](#)

Armijn Hemel: Thinking about a supply tree rather than supply chain.



“Learning about a supply tree rather than a supply chain.” Made with ChatGPT-5.6 Sol, CC0.

SBOM 逐步發展的現實與未來方向

1. **Free** as in Free Speech, still.

自由仍可貴

2. Yet **COSS** might lead in the next decades

商用開源軟體領頭

3. **Enterprise community** works together

開源協作加入商業社群

OpenChain CRA Compliance Requirements & Checklist

Files

main

Go to file

- > 1.0
- > Pre-Release-Versions
- > versions
 - ANNEX_D_EXTERNAL_REFER...
 - CONTRIBUTING.md
 - CONTRIBUTORS.md
 - CRA_Checklist_Requirement_...
 - LICENSE
 - README.md
 - REVISION_HISTORY.md

CRA-Compliance / CRA_Checklist_Requirement_latest.md

umm0 V1.0 patch 1 (#51)

20f94c7 · 4 days ago History

Preview

Code

Blame

975 lines (549 loc) · 127 KB

Raw



OpenChain CRA Compliance Requirements & Checklist

Community-Maintained Self-Certification and Readiness Resource

Regulation (EU) 2024/2847 | ISO/IEC 18974 | ISO/IEC 5230 | BSI TR-03183

Version: 1.0 | Date: 11 Sep 2026 | Status: released

License: CC-BY-4.0

OpenChain CRA Compliance page: <https://cra-compliance.openchainproject.org>

This document was developed as an open initiative with feedback received from OpenChain contributors. See Annex D

https://github.com/OpenChain-Project/CRA-Compliance/blob/main/CRA_Checklist_Requirement_latest.md

CRA-Compliance/CRA_...

github.com/OpenChain-Project/CRA-Compliance/blob/main/CRA_Checklist_Requirement_latest.md

150%

Files

main

Go to file

> 1.0

> Pre-Release-Versions

> versions

ANNEX_D_EXTERNAL_REFER...

CONTRIBUTING.md

CONTRIBUTORS.md

CRA_Checklist_Requirement_...

LICENSE

README.md

REVISION_HISTORY.md

CRA-Compliance / CRA_Checklist_Requirement_latest.md

PreviewCodeBlame975 lines (549 loc) · 127 KB

RawDownload

relevant personnel change and determine annually.

Section 5: Open Source Software (OSS) Stewardship

The definition, scope, and obligations of Open Source Software Stewards are established in CRA Art. 3(14), Recitals 18 and 19, and Art. 24. This section governs upstream engagement, license compliance, and steward vs. maintainer boundaries.

5.1 Open Source Contribution & Engagement

Policy for engaging with upstream open-source communities while maintaining CRA compliance.

Ref	Requirement	Conformant? (Yes / No / Partial)	Evidence & Rationale	Guidance / Reference
5.1.1	[GOOD PRACTICE] The organization should maintain a documented policy governing how personnel contribute to upstream open-source projects, including CLA/DCO requirements and IP assignment rules.	☐ Yes ☐ No ☐ Partial		OSS contribution policy; CLA tool configuration. OpenChain ISO/IEC 5230 as reference.

https://github.com/OpenChain-Project/CRA-Compliance/blob/main/CRA_Checklist_Requirement_latest.md

6. 善用真開源因應 CRA 合規要求

CRA 對照表

free and open-source software/open-source software steward

- Recital 17 對 FOSS 的特別考量
- Recital 18 定義 FOSS，並說明哪些商用面向應受 CRA 管理、哪些純貢獻面向除外。
- Recital 19 說明 Open-source Software Steward 制度
- Recital 20 說明 GitHub、GitLab 等託管平台得除外
- Article 3(14) 正式定義 Open-source software steward
- Article 24 規定 Open-source software steward 的義務
- Article 64(10) 規定 Open-source software steward 不適用行政罰鍰
- Article 13 (Manufacturer obligations)：商業化提供 FOSS 回歸 CRA 範圍
- Article 14 (Vulnerability handling)：Steward 須遵循部分漏洞通報義務

Regulation (EU) 2024/2847 -- CRA, Article 3(48)

(48) ‘**free and open-source software**’ means software the source code of which is **openly shared** and which is made available under a **free and open-source licence** which **provides for all rights** to make it freely accessible, usable, modifiable and redistributable; → **四大自由**

https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng#art_3



<https://faircode.io/>

Fair-code licenses

Business Source License

<https://mariadb.com/bsl11>

Commons Clause with any OSI approved open-source license

<https://commonsclause.com>

Confluent Community License

<https://www.confluent.io/confluent-community-license>

Elastic License 2.0 (ELv2)

<https://www.elastic.co/licensing/elastic-license>

Server Side Public License

<https://www.mongodb.com/licensing/server-side-public-license>

Sustainable Use License

<https://github.com/n8n-io/n8n/blob/master/LICENSE.md>

<https://faircode.io/>

Issues · aboutcode-org

github.com/aboutcode-org/scancode-toolkit/issues?q=is%3Aissue+state%3Aopen+label%3Anew-license

Platform Solutions Resources Open Source Enterprise Pricing

aboutcode-org / scancode-toolkit Public

Sponsor Notifications Fork 730 Star 2.5k

Code Issues 1.4k Pull requests 178 Discussions Actions Projects Wiki Security and quality Insights

is:issue state:open label:new-license

Labels Milestones New issue

Open 176 Closed 277

Author Labels Projects Milestones Assignees Types Newest

- New license request: QuestPilot Source Available License 1.0 new-license
#5096 · armijnhemel opened 2 hours ago
- New license request: Project Golem Source-Available Non-Commercial License Version 1.0 new-license
#5095 · armijnhemel opened 2 hours ago
- New license request: Blockchain Scalpel License v1.2 new-license
#5094 · armijnhemel opened 2 days ago
- New license request: Spectrix Source-Available Collaboration License new-license Priority: low
#5093 · armijnhemel opened 2 days ago
- New license request: Materio Source-Available License 1.0 new-license Priority: low

<https://github.com/aboutcode-org/scancode-toolkit/issues?q=is%3Aissue%20state%3Aopen%20label%3Anew-license>

Source Available $\neq$ **Open Source**

源碼可及、僅是可及

並不擔保穩定的開放式利用狀態

Source Available $\neq$ **Open Source**

見源軟體、**看得到****不一定摸得著**

意思就是能不能用還要再考究

Meta 喬不定只能回歸開源的共識規則……

Llama 1: **GPL-3.0 Code** + **Non-commercial Weights**

Llama 2–4: Respective **Llama Community Licenses**

Muse Glimmer 30B: **Apache-2.0** + **Usage Policy**

Muse Spark 1.3: **Proprietary** / API Only

Meta AI 模型在**開源**、**開放權重**與**專有模式**之間的歷史游移

LICENSE · meta-mod x AGNTCon + MCPCon x AGNTCon + MCPCon x AGNTCon + MCPCon x Events - Agentic AI F x AGNTCon + MCPCon x +

huggingface.co/meta-models/Muse-Glimmer-30B/blob/main/LICENSE 170%

 **Hugging Face** Search models, datasets, Models Datasets Spaces Docs Pricing Log In Sign Up

meta-models/**Muse-Glimmer-30B** like 1.86k Follow Meta Inc. 2k

Image-Text-to-Text Transformers Safetensors muse_glimmer conversational Eval Results arxiv:2504.13181

arxiv:2602.06036 License: apache-2.0

Model card Files xet Community 62 Deploy Copy to bucket NEW Use this model

main Muse-Glimmer-30B / LICENSE

betodepaola Add Apache-2.0 license and usage policy f84ecc3 VERIFIED 30 days ago

Raw Download with hf CLI Copy download link History Blame Contribute Delete Safe 11.4 kB

```
1
2           Apache License
3           Version 2.0, January 2004
4           http://www.apache.org/licenses/
5
6  TERMS AND CONDITIONS FOR USE, REPRODUCTION AND DISTRIBUTION
```

<https://huggingface.co/meta-models/Muse-Glimmer-30B/blob/main/LICENSE>

歐盟《Cyber Resilience Act》（CRA）

1. Open-source Software Steward

- (1) 維運資安政策 (2) 配合市場監督 (3) 提供相關文件
- (4) 重大資安事件或已遭利用漏洞的通報與公告 (5) 不適用行政罰鍰（administrative fines）

2. Open-source Software 資安認證緩衝

- 一般產品 / 重要產品 Class I / 重要產品 Class II / 關鍵產品 Critical
- 數位元素 / 身份存取、密碼管理 / 防入侵、防竄改機制 / 安全盒、智慧閘道總樞
- 資安可自評 / 建立流程標準可自評或第三方評鑑 / 第三方評鑑 / 指定資安認證方案

技術文件開源可及者、Class I + Class II 可轉為自評

CRA 時代的 **Open Source Compliance**

配合 CRA 施行，企業應該如何**重新思考**開源軟體的治理模式。

1. Free Riding → **Efficient Riding**

2. Working with FOSS by **Upstreaming**

Vulnerability Disclosure

1. 漏洞通報義務 --2026.9

2. 盤點產品線裡哪些 FOSS 已有 **Steward**

ASF / Eclipse Foundation / The Linux Foundation / Python Software Foundation / Mozilla Foundation / Document Foundation / KDE e.V. / GNOME Foundation / OpenJS Foundation / Rust Foundation / OpenInfra Foundation / OSGeo Foundation

3. 盤點產品線裡哪些 FOSS 已有 **Commercial Support**(試舉 10 例)

Red Hat (IBM) / SUSE / Canonical / GitLab / Percona / Confluent / Elastic / MariaDB plc / Docker / IBM (HashiCorp)

4. **保持**所使用開源元件或商業授權元件的**版本號**

5. 資安補正透過溯源 (**upstream**) 方式實踐

6. **資安修復** (可委外) / **資安通報** (可部份委外) / **資安告知** (應承擔)

Made available to the public

Publicly Available

Quoting a European Commission presentation at FOSDEM2024 (11min54):

When it comes to FOSS, we have a special provision in the CRA that says that irrespective of whether your product is important or not, you will always be allowed to undergo a self-assessment. You will not have to submit any FOSS that is in the scope of the CRA to a third party.

And the reason behind that is that when it comes to open source it is a transparent product and anyone including the users or integrators they can check for themselves if this product is secure. So you do not need a third-party that vouches for the product.

This seems useful. It will empower all users, not just notified bodies or economic actors with sufficient market power to inspect the security of the products they rely on. Perhaps it will incentivize some *manufacturers* to open up their products.

<https://blog.nlnetlabs.nl/what-i-learned-in-brussels-the-cyber-resilience-act/>

Regulation (EU) 2024/2847 第 32 條第 5 項：

Manufacturers of products with digital elements qualifying as **free and open-source software**, which fall under the categories set out in **Annex III**, shall be able to demonstrate conformity with the essential cybersecurity requirements set out in Annex I by using one of the procedures **referred to in paragraph 1 of this Article**, **provided that the technical documentation referred to in Article 31 is made available to the public** at the time of the placing on the market of those products.

若是**自由開源軟體**，即使屬於附件三（**Annex III**）重要產品類別之元件，製造商仍可選擇第 32 條第 1 項的程序進行**自我資安評估**，而不限定經第三方程序進行資安檢測。

https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202402847

7. 開源與各國法令的交集與調適

公眾授權條款

General Public License

- 1、對公眾皆可適用、永久有效
- 2、規則一致、條件一致
- 3、原則上沒有增刪修改異動相關內容的機會

公眾授權**建立信任**

因為授權模式全球相通

而且**不能** / **很難更改**

License Steward

**GPL-FSF 、 MPL-Mozilla Foundation 、 Apache-2.0-ASF 、 EPL-
Eclipse Foundation 、 Creative Commons License Suite-CC**

Open Source as the **Business Intelligence**

Understanding US

← → ↻ 🏠 🔒 https://www.linuxfoundation.org/resources/publications/understanding-us-export-controls-with-open-source-projects 📄 🔍 ☆ 📧 👤 📌 ☰

PUBLICATION

Understanding US export controls with open source projects

DOWNLOAD REPORT

One of the greatest strengths of open source development is how it enables collaboration across the entire world. However, because open source development is a global activity, it necessarily involves making available software across national boundaries. Some countries' export control regulations, such as the United States, may require taking additional steps to ensure that an open source project is satisfying obligations under local regulations.



In July of 2020, The Linux Foundation published a whitepaper on how to address these issues in detail. In 2021, the primary update in the paper is to reflect a change in the US Export Administration Regulations.



DOWNLOAD REPORT

<https://www.linuxfoundation.org/resources/publications/understanding-us-export-controls-with-open-source-projects>

美國出口管制規則 (**EAR**):

1. 雖然主體管的是專利 (技術)
2. 但軟體出口不是不管
3. 然軟體已先行公開 (**publicly available**) 者、低度管制，
4. 僅其中涉及加密 (**encryption**) 技術者、要管
5. 然若此**加密技術若亦公開可及、電郵備查**



https://archive.fosdem.org/2024/events/attachments/fosdem-2024-3683-the-regulators-are-coming-one-year-on/slides/22201/Slides_CRA_FOSDEM_v3_ukPnQUG.pdf

《加州 AI 透明法》

SB 942 《 California AI Transparency Act 》

2026 SB 1000 修正

GenAI hosting platform

所提供的 AI 模組若不予標示則撤回授權 →

當得知所提供的 AI 模組若不予標示則告知其違反法規

《加州年齡驗證法案》

AB-1856 《 California's Age Verification Bill 》

Operating System Provider

資訊系統平台未來可能被要求負責取得、判定並提供使用者年齡區間訊號 →
純粹提供自行安裝的開源軟體作業系統 (Open Source Operating System) 除外

Thanks! 謝謝 !